

GDPR Compliance Audit Report

Automated security and privacy compliance scan

www.nwreflections.co.uk

SCAN DATE

Sunday, 31 May 2026 at 13:30

REPORT GENERATED

31 May 2026

EXECUTIVE SUMMARY



HIGH RISK

This report summarises an automated security and GDPR compliance scan of **www.nwreflections.co.uk**. Seven checks were performed covering HTTPS security, HTTP security headers, email authentication, open port exposure, subdomain enumeration, technology disclosure, and GDPR compliance requirements.

10

TOTAL ISSUES

2

FAILED CHECKS

2

WARNINGS

7

CHECKS RUN

KEY FINDINGS

SECURITY HEADERS

Missing header: Content-Security-Policy (critical)

SECURITY HEADERS

Missing header: X-Frame-Options

SECURITY HEADERS

Missing header: Referrer-Policy

SECURITY HEADERS

Missing header: Permissions-Policy

DNS RECORDS (EMAIL SECURITY)

No SPF record found

DETAILED SCAN RESULTS

SSL / TLS Certificate

WARNING

Certificate validity, expiry, TLS version (1.2+), cipher strength.

- Certificate expires in 24 days

WHAT TO DO

Renew your SSL certificate before it expires. Let's Encrypt provides free, auto-renewing certificates.

⚠ BUSINESS IMPACT

Your certificate is approaching expiry — visitors will start seeing warnings.

WHAT COULD HAPPEN:

- Browsers display 'Not Secure' warnings that drive visitors away immediately
- Google may lower your search ranking for security issues
- Payment and login data could be transmitted over an insecure connection
- GDPR requires adequate technical security — an expired certificate is a violation

Responsible: Your web host or web developer.

Cost to fix: 30 minutes. Free renewal via Let's Encrypt.

Security Headers

FAIL

CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.

- Missing header: Content-Security-Policy (critical)
- Missing header: X-Frame-Options
- Missing header: Referrer-Policy
- Missing header: Permissions-Policy

WHAT TO DO

Add Content-Security-Policy and Strict-Transport-Security headers as urgent priorities. Use securityheaders.com to verify.

⚠ BUSINESS IMPACT

No browser security protections — customer data and your reputation are at risk.

WHAT COULD HAPPEN:

- Attackers can inject malicious scripts (XSS) to steal credit card numbers and personal data
- Your site can be embedded in a hidden iframe to trick users into giving up login credentials (clickjacking)
- Google Safe Browsing may blacklist your domain — you disappear from search results overnight
- Customers whose data is stolen can sue you under GDPR for failing to implement basic security
- GDPR fine: up to £17.5 million for inadequate technical security measures
- Remediating a hacked site costs £1,000–£10,000+ and weeks of downtime

Responsible: Your web host or web designer.

Cost to fix: 30 minutes. No code changes needed — server configuration only.

DNS Records (Email Security)

FAIL

SPF, DKIM, and DMARC TXT records for email spoofing prevention.

- No SPF record found
- No DKIM record found (checked common selectors)
- No DMARC record found

WHAT TO DO

Add SPF, DKIM, and DMARC records immediately. Without them, attackers can send spoofed emails from your domain.

⚠ BUSINESS IMPACT

Anyone can send emails pretending to be your business — this is a serious fraud risk.

WHAT COULD HAPPEN:

- Attackers send phishing emails to your customers 'from' your domain — stealing money and data
- Customers report fraud, raise chargebacks, and leave negative reviews about your 'scam emails'
- Your domain is permanently blacklisted by major email providers
- Your legitimate invoices and quotes land in spam — you lose business deals
- Legal liability if a customer is defrauded using your domain identity
- Average cost of an email fraud incident: £3,000–£30,000 in losses and remediation

Responsible: Your DNS/domain provider or IT administrator.

Cost to fix: 15 minutes. Completely free to fix.

Open Ports

PASS

Ports 80, 443, 22 (SSH), 3306 (MySQL), 5432 (PostgreSQL), 8080, 3000, 27017 (MongoDB).

✓ No issues found.

Subdomain Enumeration

ERROR

Public certificate transparency logs (crt.sh) — passive, no active probing.

Error: Request failed with status code 502

✓ No issues found.

Technology Detection

PASS

CMS, frameworks, server software, and version disclosures.

✓ No issues found.

GDPR Compliance

WARNING

Privacy policy, cookie consent banner, tracking scripts, data subject rights.

- No cookie consent mechanism detected
- No data subject rights information detected

WHAT TO DO

Add the missing GDPR elements. A privacy policy and cookie consent banner are legally required for EU/UK visitors.

⚠ BUSINESS IMPACT

Incomplete GDPR compliance — regulatory risk is building.

WHAT COULD HAPPEN:

- ICO (UK data regulator) can investigate based on a single complaint from any visitor
- Missing cookie consent means you are collecting and processing data without a legal basis
- Privacy advocates and competitors can file regulatory complaints against your business
- Without consent records, you cannot prove compliance if investigated
- Fines for incomplete compliance typically range from £4,000 to £500,000 depending on severity

Responsible: You are legally responsible as the data controller — this cannot be delegated.

Cost to fix: 1–2 hours to add missing elements. Consent management tools: free to £50/month.

RECOMMENDATIONS

Actions recommended to improve your security and GDPR compliance posture, sorted by severity.

1. DNS RECORDS (EMAIL SECURITY)

Add SPF, DKIM, and DMARC records immediately. Without them, attackers can send spoofed emails from your domain.

2. SECURITY HEADERS

Add Content-Security-Policy and Strict-Transport-Security headers as urgent priorities. Use securityheaders.com to verify.

3. SSL / TLS CERTIFICATE

Renew your SSL certificate before it expires. Let's Encrypt provides free, auto-renewing certificates.

4. GDPR COMPLIANCE

Add the missing GDPR elements. A privacy policy and cookie consent banner are legally required for EU/UK visitors.

GDPR COMPLIANCE CHECKLIST

Summary of GDPR-relevant requirements assessed during this scan.

- ✓ Privacy policy present on website
- ✗ Cookie consent mechanism implemented
- ✓ No tracking scripts without consent banner
- ✗ Data subject rights information present
- ✓ HTTPS enabled (data encrypted in transit)
- ✗ Critical security headers configured
- ✗ Email authentication configured (SPF / DKIM / DMARC)
- ✓ No unnecessary ports exposed (access control)

Disclaimer: This report was generated by SecureVault automated scanning tools and is provided for informational purposes only. It does not constitute legal advice and does not guarantee GDPR compliance or freedom from regulatory action. Results reflect the publicly observable state of the website at the time of scan and may not capture all security vulnerabilities. Always consult a qualified security professional for comprehensive auditing. Generated on 31 May 2026.